

MEMORANDUM

To: Responsible AI Lead, [Bank]
From: AI Platform Director (sponsoring)
Date: [Date]
Subject: Recommendation — HoneyHive as the agent observability and evaluation control layer for production AI deployments

Recommendation

Adopt HoneyHive as the standard observability and evaluation control layer for all production agent deployments. Use the trace-level evidence it produces as the primary basis for model risk review and ongoing monitoring under the bank's existing MRM (Model Risk Management) framework. A 90-day evaluation period is proposed before broader rollout.

Background

The bank currently has 5 agents in pre-production and approximately 45 additional use cases queued for the next 12 months. Deployments are blocked pending demonstrated controls for three failure modes identified by Responsible AI:

1. **Hallucinations** — agents generating content that is not grounded in retrieved data or established policy.
2. **PII (Personally Identifiable Information) leakage** — customer data appearing in unauthorized contexts within agent execution paths.
3. **Unauthorized actions and tool misuse** — agents calling tools, with parameters, or in sequences that fall outside approved policy.

Existing controls — the LLM gateway, AWS Bedrock Guardrails, and the homegrown PII redaction service — operate at the request boundary. They do not produce trace-level evidence of agent behavior across multi-step executions, which is the level at which the three failure modes above manifest.

Why this gap matters under SR 11-7

SR 11-7 (Federal Reserve Supervisory Letter 11-7) requires sound model risk management practices, including ongoing monitoring, outcomes analysis, and clear documentation of model behavior. Traditional ML (Machine Learning) models satisfy this through point-in-time validation and periodic backtesting. Agentic systems do not fit that pattern: their behavior is non-deterministic, their decision paths are multi-step, and their "outputs" include sequences of tool calls rather than a single prediction.

Without trace-level instrumentation, the bank cannot produce the evidence MRM requires to approve these systems for production, nor monitor them for drift after approval.

What HoneyHive provides

HoneyHive is an OpenTelemetry-native observability and evaluation platform purpose-built for AI agents. It produces trace-level records of agent execution — every model call, every tool call, every retrieval — and runs continuous evaluators against those traces to detect the failure modes above.

The relevant capabilities, mapped to MRM concerns:

RAI Concern	Required Evidence	HoneyHive Capability	Cadence
Hallucinations	Quantitative measure of factual grounding per release; ability to detect regression	Online LLM-as-a-judge evaluators for faithfulness and context relevance, run continuously against production traces	Continuous; aggregated per release
PII leakage	Detection across all execution layers — inputs, outputs, intermediate tool calls, retrieved context	Custom code evaluators for PII patterns, applied to every span in a trace	Continuous
Unauthorized tool use	Trace-level record of every tool call; deviation from approved baseline	Tool-call instrumentation as structured spans; custom evaluators flagging out-of-policy calls and suspicious sequences	Continuous; baseline reviewed quarterly
Model and behavior drift	Comparison of current behavior against approved baseline	Versioned datasets, side-by-side experiment comparison, regression tests gated in CI/CD	Per release; quarterly review
Evidence for audit	Persistent, queryable record of all production agent executions	Trace storage with full input/output capture; exportable to existing audit systems	On demand

The platform is framework-agnostic via OpenTelemetry, which matters because the bank's 5 production agents run on three different frameworks (LangGraph, AWS Bedrock Agents, CrewAI). A single instrumentation pattern covers all current and future frameworks without per-agent rework.

Deployment posture

HoneyHive offers a self-hosted deployment within the bank's AWS VPC (Virtual Private Cloud). Production traces — which contain customer data and prompts — never leave the bank's infrastructure. The vendor is SOC 2 Type II certified, GDPR and HIPAA compliant.

This posture materially reduces the third-party risk surface compared to multi-tenant SaaS vendors:

- No customer data leaves the bank's environment.
- No new data residency concerns.
- Existing CISO controls for AWS workloads apply.
- The AI-specific procurement addendum (training data usage, model provenance) applies narrowly, since the vendor does not train on customer data.

What this memo recommends RAI commit to

This is not a request to approve a software purchase. The platform team will manage procurement through existing channels. What is requested from Responsible AI:

1. Acceptance of trace-level evidence, produced by HoneyHive, as a valid input to model risk review for agent-based systems.

2. Agreement on a defined review cadence — proposed: pre-deployment review, 30-day post-deployment review, then quarterly — using HoneyHive dashboards and exports as the evidence base.

3. Joint definition, with the platform team, of the specific evaluators and thresholds that constitute "approved baseline" for each agent. This is a one-time exercise per agent type, reusable across instances.

A 90-day pilot on one production agent (proposed: the fraud triage agent, given its mature instrumentation and lower customer-impact risk) would generate the first round of evidence and surface any gaps in the control mapping above before broader rollout.

What this memo does not yet address

Prompt injection and jailbreaks. HoneyHive's evaluator framework can detect these post-hoc but does not prevent them. A separate control layer (input filtering, prompt hardening) is required and is out of scope for this recommendation.

Bias in customer-impact decisions. Out of scope for the initial deployment. A follow-on workstream is recommended once the three primary failure modes are under continuous monitoring.

Specific evaluator thresholds. The memo proposes the framework; the actual numeric thresholds (acceptable hallucination rate, PII detection precision, etc.) require joint definition between Responsible AI, the platform team, and the relevant business line owners. This is by design — these thresholds are policy decisions, not vendor decisions.

Cost of internal alternative. A build-vs-buy analysis is being prepared separately by the platform team. Initial estimate: 2–3 platform engineers for 9–12 months to reach feature parity, before ongoing maintenance. The vendor cost is materially lower and, more importantly, faster to evidence.

Next steps

1. RAI review of this memo and the proposed control mapping.
2. Joint working session — RAI, platform team, fraud triage agent owner — to define evaluator thresholds for the 90-day pilot.
3. Pilot execution; first review at day 30.
4. Decision point at day 90 on broader rollout to remaining agents.